TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

CISA adds exploited GitLab RCE and Cisco ASA/FTD DoS flaws to KEV

From **Cybersecurity Briefing** · 2026-10-29 to 2026-11-03 · Briefing generated 2026-11-03

REPORT ID	VERSION	HANDLING
CTI-20261103-02	1.0 · 2026-11-03 08:48 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
	2026-10-30	No update
CVES	**ANALYST**	
CVE-2026-97229 (CVSS 10.0), CVE-2026-76418 (CVSS 8.6)	Nick Sturgeon	

VULNERABILITY | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 2026-10-29 CISA added two flaws to its Known Exploited Vulnerabilities (KEV) catalog with a federal due date of 2026-11-01, which has now passed [S1] [S2] [S3]. CVE-2026-97229 (CVSS 10.0) is an integer overflow in the CI/CD regular expression compiler of self-managed GitLab CE/EE that can lead to code execution on the server [S4] [S8]. CVE-2026-76418 (CVSS 8.6) lets an unauthenticated remote attacker force a Cisco Secure Firewall ASA or FTD device to reload by sending a crafted request to the SSL remote access VPN, but only where secondary authentication is configured on a tunnel group [S5] [S15]. The two flaws are unrelated; CISA listed them together only because both were added on the same day.

The GitLab flaw is the larger risk. Rapid7 published a working proof of concept on 2026-10-13, one day after the fix [S14] [S25], and the CVE record references a Metasploit pull request (not opened for this report) [S4]. Alpine Linux disclosed that a newly registered account attacked its GitLab server on 20-21 October, crashing workers eight times, with four attempts getting partway through the exploit [S11]. The briefing excerpt calls this a failed attempt, but Alpine's position is narrower: it found no evidence of code execution, could not rule it out because some logs were gone and outbound traffic was not logged, and rebuilt the server [S11] [S12]. CISA marks forensic triage as required for this CVE, not only patching [S3]. A clean upgrade can also be false assurance. GitLab's fix is a Ruby patch shipped only in official packages and images, so self-compiled installs and custom images stay vulnerable until Ruby itself is updated to 3.3.13, 3.4.12, 4.0.9 or later [S9] [S10] [S11]. Alpine was caught this way on GitLab 19.3.6 [S11]. Patch to the newest release for your branch rather than the first fixed one, because a sibling flaw, CVE-2026-

110264 (CVSS 10.0), reaches back to GitLab 7.0 and needs 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10, 18.11.13 or later [S9].

The Cisco flaw affects availability only: Cisco rates confidentiality and integrity impact as none, and CISA does not require forensic triage for it [S3] [S5] [S15]. Cisco's PSIRT says it became aware of active exploitation in October 2026 [S15]. That is the date Cisco learned of it, not necessarily when attacks began, as the briefing excerpt implies; the start date is undisclosed [S23]. Cisco has published no indicators, actor, victim count or crash signature [S15] [S29]. Cisco offers no true workaround, only temporary mitigations that either change how users pick a connection profile or remove secondary authentication, which weakens VPN security [S15].

Still unknown: who is behind either campaign, how many organizations were hit, what evidence supports CISA's listing, and how the GitLab attack could work without the project write access Rapid7's route needs [S13]. No IP addresses, domains or hashes have been published for either CVE, so hunting must rely on behavior. What to do: upgrade self-managed GitLab now and verify the Ruby version, hunt logs back to 2026-10-12 before they rotate, rotate secrets if anything looks wrong, and upgrade any ASA/FTD device that meets Cisco's three exposure conditions [S11] [S15] [S16] [S17].

Key judgments

VERY LIKELY · HIGH CONFIDENCE
Exploitation attempts against unpatched self-managed GitLab servers will continue or increase over the next 30 days, given a public proof of concept, CISA's 'automatable' rating, an EPSS score in the 98th percentile, and large exposure counts. [S3] [S4] [S13] [S14] [S24] [S25] [S31]

LIKELY · MODERATE CONFIDENCE
Version-based scans and patch dashboards will understate GitLab exposure for the rest of this patch cycle, because self-compiled installs and custom images can report a fixed GitLab version while running a vulnerable Ruby. [S9] [S10] [S11] [S22]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
At least one organization will publicly confirm a real GitLab compromise through CVE-2026-97229 within 30 days. CISA reports active exploitation but no confirmed compromise has been named, and a successful exploit can leave little trace. [S2] [S11] [S17] [S24]

LIKELY · MODERATE CONFIDENCE
Attacks forcing reloads of exposed Cisco ASA/FTD VPN gateways will continue over the next 30 days, as the advisory and KEV listing draw attention to the flaw and CISA rates it automatable, though no public reproducible exploit was reported as of late October. [S5] [S15] [S23] [S30]

VERY UNLIKELY · MODERATE CONFIDENCE
CVE-2026-76418 will be shown to allow code execution or data theft on its own. All authoritative descriptions limit it to a device reload, though Cisco has not explained why attackers are using it, so its use alongside other activity cannot be excluded. [S5] [S15] [S27]

INDICATORS OF COMPROMISE

No IP addresses, domains, hashes or attacker infrastructure have been published for either CVE in the sources reviewed as of 2026-11-03; Alpine's post, Cisco's advisory and BleepingComputer's report contain none [S11] [S15] [S24]. The entries below are behavioral and log artifacts from GitLab's detection rules, Rapid7's analysis and Cisco's exposure conditions, published in October 2026. Treat them as hunting leads, since GitLab warns that a successful exploit may leave none of them.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`GET /api/v4/projects/<project>/ci/lint?content_ref=<commit>`	CI lint trigger on Rapid7's demonstrated route. In Workhorse logs, look for a request running several seconds, then a backend EOF and HTTP 502. Rapid7 describes GET while GitLab's rules match POST, so hunt both methods.	REPORTED		[S13]
http-request	`POST */ci/lint or POST /api/graphql returning HTTP 502`	GitLab's Workhorse crash rule. A single event is enough to investigate, because a normal lint request finishes well under a second. Rule out wider outages and restarts.	REPORTED		[S17]
http-request	`GraphQL query_string containing ciLint with hostile patterns in variables`	Probe visible in graphql_json.log. Inline CI content is logged as <REDACTED>, so only the variable form can be seen.	REPORTED		[S8] [S16]
other	`badgateway: failed to receive response: EOF`	Workhorse error string for a backend that died during a lint or GraphQL request. Strongest when the correlation_id is missing from api_json.log and graphql_json.log.	REPORTED		[S17]
other	`Workhorse read_bytes > 1000000; duration_ms near 59000 or 2000-3000`	Confidence boosters only. Request bodies around 2 MB match the attack payload; about 59 s suggests a hang ending at rack-timeout; 2-3 s suggests an OOM kill during compilation.	REPORTED		[S17]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`\{[0-9]*\(\?#[^)]*\)[0-9,]*\}`	Regex matching a comment-split counted repeat, the construct tied to the CVE-2026-97229 guard bypass. GitLab rates it highest concern. Search GraphQL variables, extra.regexp and committed CI files.	REPORTED		[S13] [S16] [S18]
other	`\{[0-9]{4,}[,}]`	Regex matching an oversized counted repeat of four or more digits. GitLab links this shape to the related CVE-2026-93577.	REPORTED		[S16]
other	`\g< or \K in a CI regular expression`	Subroutine call and keep operator. GitLab says these have no legitimate use in a CI path filter.	REPORTED		[S16] [S18]
other	`Gitlab::Ci::Build::Rules::Rule::Clause::RegexpMatcher`	class_name in application_json.log at WARN with a message containing 'rejected at compile time', 'match timed out' or 'time budget exceeded'. Marks a probe the safety guard caught.	REPORTED		[S18]
other	`[BUG] with regexp_matcher.rb, onig_compile, compile_tree or compile_length_tree`	Ruby native crash report for the CI compile-time path in puma_stderr.log. Often not collected by default, and silent success or an OOM kill leaves no such report. GitLab's full rule also matches other frames.	REPORTED		[S21]
other	`A worker terminated, shutting down the cluster`	Sidekiq log line for the pipeline vector, where a pushed .gitlab-ci.yml crashes Sidekiq and produces no Workhorse 502.	REPORTED		[S17] [S21]
filename	`.gitlab-ci.yml`	Carrier of the crafted regex. Review recent commits from new or unexpected accounts, particularly rules:exists:regexp and rules:changes:regexp, split repeat quantifiers and repeated POSIX word classes.	REPORTED		[S11] [S13] [S18]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Committed path segment near 255 bytes with a non-ASCII byte in the final segment`	Trigger for CVE-2026-97229. In logs, a segment of 200 or more characters containing a percent-encoded UTF-8 lead byte (%C2 to %F4). A commit followed within minutes by ci/lint on the same branch is the attack sequence.	REPORTED		[S13] [S19] [S20]
user-agent	`python-urllib, python-requests, curl, wget, libwww, HTTPie, okhttp, or empty`	Scripted clients. GitLab's rule fires on 3 or more POST ci/lint requests returning 500, 502, 503 or 504 from one client within 6 hours. These user agents are common, so they are not malicious alone.	REPORTED		[S20]
filepath	`/tmp (files owned by git)`	GitLab's follow-up check for quiet success. Not specific alone, since legitimate git-owned temp files may exist.	REPORTED		[S16] [S17] [S21]
command	`Shell child process spawned by a Puma or Sidekiq worker, running as git`	Rapid7's chain ends in a command run as the git OS account, and GitLab lists unexpected Puma or Sidekiq children as a success indicator. Rapid7 notes the attack path used in the wild may differ from its own.	REPORTED		[S13] [S16] [S21]
other	`Puma worker memory increase of roughly 2 GiB`	Host signal in Rapid7's analysis, caused by the oversized compiled regex program. Offsets and sizes are build-specific.	REPORTED		[S13]
other	`Changed crontab or SSH keys for the git user`	GitLab's listed checks for persistence after a successful exploit.	REPORTED		[S21]
filepath	`/var/opt/gitlab/.ssh/authorized_keys`	Derived from GitLab's instruction to check the git user's SSH keys, using the usual Linux package home for that account. GitLab manages this file, so look for entries not created by GitLab Shell. Confirm the path on your install.	DERIVED		[S21]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`New account downloading the GitLab instance's own container image or build artifacts`	Derived from Alpine's report that its attacker downloaded its GitLab image, apparently to tune the exploit to that exact build. Applies mainly to organizations that publish custom GitLab images. Alpine's image was public, so a pull may not be attributable.	DERIVED	2026-10-21	[S11] [S22]
other	`alpinelinux/gitlab:19.3.6 image pulled before 2026-10-27, or any older tag`	Exposure marker, not a compromise indicator. Alpine says these images are vulnerable and must be re-pulled.	REPORTED		[S11]
other	`secondary-authentication-server-group`	Cisco exposure condition, not a compromise indicator. Check every tunnel group where tunnel-group-list enable is present, and DefaultWEBVPNGroup in all cases.	REPORTED		[S15]
other	`webvpn with enable <interface_name>`	Cisco exposure condition, not a compromise indicator. Shows that SSL remote access VPN is enabled on an interface.	REPORTED		[S15]
port	`443/tcp`	Derived: the crafted request must reach the SSL VPN login service, which normally listens on HTTPS. Administrators can change the port, so confirm it per device. Cisco does not state a port.	DERIVED		[S15]
other	`Unexplained ASA/FTD reload, with repeated SSL VPN connection attempts just before it`	Vendor-analyst guidance, not Cisco's. Cisco publishes no crash signature or syslog ID. Forward logs off the device because a reload can disrupt local evidence and upstream telemetry may be the better record.	REPORTED		[S29] [S30]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

GitLab: on the route Rapid7 demonstrated, the attacker commits a malicious .gitlab-ci.yml and a long UTF-8 repository path to a branch of a public project, which is easy where users can self-register and create projects. An inline comment inside a repeat quantifier hides the true bound from GitLab's scanner, the Onigmo engine compiles an oversized program, and an integer overflow redirects execution into attacker-influenced data. An unauthenticated CI lint request triggers it, and a command runs as the git OS account [S13] [S14]. At Alpine, a new account sent crafted CI configurations, downloaded the GitLab image, and returned after being blocked; whether code ran is undetermined [S11] [S22]. Cisco: a crafted request sent while connecting to the SSL VPN, with no successful login needed, reaches faulty logic tied to secondary authentication, causing a NULL pointer dereference and a reload [S5] [S15]. Cisco has not described the request or how attackers are using it.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1592.002 Gather Victim Host Information: Software	The attacker downloaded Alpine's GitLab container image. Alpine believes this was to tune the exploit to its exact build. [S11] [S22]	Review registry pulls of internal GitLab images by new or unusual accounts. Public images may not be attributable.
Persistence	T1136 Create Account	A newly registered account did the probing on 20 October and the attacker tried to regain access on 25-26 October after being blocked. Rapid7 notes open registration satisfies its prerequisites. [S11] [S14]	Alert on new accounts that soon create projects, commit CI files or call ci/lint.
Initial Access	T1190 Exploit Public-Facing Application	Crafted regex in CI/CD configuration reaches the Onigmo compiler through the CI lint route (CVE-2026-97229). [S4] [S13] [S16] [S17] [S18]	Workhorse 502s on ci/lint or /api/graphql with a correlation_id missing from Rails logs; regex guard rejections; hostile patterns in ciLint variables.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Demonstrated by Rapid7, which reproduced a command running as the git account. Not confirmed at Alpine. [S13] [S21]	EDR or auditd alerts on shells spawned by Puma or Sidekiq workers.
Credential Access	T1110.004 Brute Force: Credential Stuffing	Alpine reports automated logins using passwords leaked from other sites. It has not tied this activity to the CVE-2026-97229 attacker. [S11] [S12]	Watch for failed-login bursts and successful logins from unfamiliar sources; require MFA.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1552 Unsecured Credentials	Potential follow-on, not observed: code execution would expose CI/CD variables, runner tokens, 2FA secrets, and webhook, integration and mirror credentials. [S11] [S12]	Log outbound connections from the GitLab host and review use of runner and API tokens after any suspect window.
Collection	T1213.003 Data from Information Repositories: Code Repositories	Potential follow-on, not observed: private repositories and confidential issues and merge requests would be reachable. Alpine saw no private data returned in the web or API requests it could review. [S11]	Review unusual clone and archive volume, and outbound transfers from the host.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	A crafted SSL VPN request forces an ASA/FTD reload (CVE-2026-76418). GitLab exploit attempts also crashed workers, causing 502 errors and failed CI jobs at Alpine. [S5] [S11] [S15] [S30]	Unexpected reloads or uptime resets on VPN gateways, correlated with external monitoring and connection logs; GitLab worker respawns.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

GitLab CI lint or GraphQL backend crash (Workhorse 502) `SPLUNK SPL`

```
index=gitlab sourcetype="gitlab:workhorse" (uri="*ci/lint*" OR uri="*/api/graphql*") (status=502 OR
error="*badgateway*")
| eval large_body=if(read_bytes>1000000,"yes","no")
| table _time host method uri status error duration_ms read_bytes large_body remote_ip user_agent
correlation_id
| sort 0 _time
```

Adapted from GitLab's rule [S17] with the POST filter removed because Rapid7 describes a GET route [S13]. Replace index and sourcetype. Check each correlation_id against api_json.log and graphql_json.log; a missing entry is the strongest sign. remote_ip can be spoofed through X-Forwarded-For. No hit does not prove safety.

GitLab CI regex guard rejection with hostile constructs `KQL`

```
GitLabApplicationLog_CL
| where class_name == "Gitlab::Ci::Build::Rules::Rule::Clause::RegexpMatcher"
| where severity == "WARN"
| where message has_any ("rejected at compile time", "match timed out", "time budget exceeded")
| extend comment_split = extra_regexp matches regex @"\{[0-9]*\(\?#[^)]*\)[0-9,]*\}",
         oversized_repeat = extra_regexp matches regex @"\{[0-9]{4,}[,}]",
         subroutine_or_keep = extra_regexp contains @"\g<" or extra_regexp contains @"\K"
| project TimeGenerated, message, extra_regexp, comment_split, oversized_repeat, subroutine_or_keep,
meta_user, meta_client_id, meta_caller_id, meta_project, meta_remote_ip, correlation_id
| order by comment_split desc, TimeGenerated desc
```

Based on GitLab's rule [S18]. The table and flattened field names are placeholders for your custom log ingestion of application_json.log. This catches probes the guard stopped, not a request that bypasses it. Read extra_regexp to separate complex but benign filters from attack constructs.

GitLab Puma native crash in the Onigmo CI compile path `SIGMA`

```
title: GitLab Puma Native Crash in Onigmo CI Regex Compile Path
status: experimental
logsource:
  product: gitlab
  service: puma_stderr
detection:
  selection_bug:
    message|contains: '[BUG]'
  selection_frames:
    message|contains:
      - 'regexp_matcher.rb'
      - 'onig_compile'
      - 'compile_tree'
      - 'compile_length_tree'
  condition: selection_bug and selection_frames
falsepositives:
  - Unrelated Onigmo crash
  - Replayed crash logs from backups or test systems
level: high
```

A narrowed form of GitLab's rule [S21]. It assumes the whole crash report arrives as one event and that puma_stderr.log is collected, which is often not the default. Treat as corroboration. It misses silent success, OOM kills and Sidekiq crashes.

ASA/FTD log silence suggesting an unexpected reload `SPLUNK SPL`

```
index=network sourcetype="cisco:asa" earliest=-30d
| sort 0 host -_time
| streamstats current=f last(_time) as next_event by host
| eval silence_sec=next_event-_time
| where silence_sec>120
| eval silence_start=strftime(_time,"%F %T"), logs_resume=strftime(next_event,"%F %T")
| table host silence_start logs_resume silence_sec
```

Generic because Cisco publishes no syslog ID or crash signature for this flaw [S15]. Tune the gap to each device's log volume, then compare hits with change records, uptime and SSL VPN connections in the minutes before the gap. Confirm any unexplained reload through a Cisco TAC case [S29].

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
GitLab CE/EE (self-managed)	19.2 before 19.2.8; 19.3 before 19.3.5; 19.4 before 19.4.2. Also any install using its own unpatched Ruby, regardless of GitLab version.	19.2.8, 19.3.5, 19.4.2 as first fixed; use the newest branch release to also cover CVE-2026-110264. GitLab.com and Dedicated are already patched.	CVE-2026-97229	10.0	0.273 (98th percentile, 2026-11-02)	Yes (added 2026-10-29)	2026-11-01
GitLab CE/EE (self-managed), sibling flaw	7.0 before 18.11.13; 19.0 before 19.0.10; 19.1 before 19.1.9; 19.2 before 19.2.9; 19.3 before 19.3.6; 19.4 before 19.4.3; 19.5 before 19.5.1	18.11.13, 19.0.10, 19.1.9, 19.2.9, 19.3.6, 19.4.3, 19.5.1	CVE-2026-110264	10.0	0.013 (71st percentile, 2026-11-02)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Ruby (under self-compiled GitLab and custom images; any app compiling untrusted regexes)	3.3 before 3.3.13; 3.4 before 3.4.12; 4.0 before 4.0.9 for all fixes. Ruby 3.2 is end of life and gets no fix.	3.3.13, 3.4.12, 4.0.9 or later	`CVE-2026-97229` and `related GitLab-assigned CVEs (Ruby has no CVEs of its own)`	10.0 (GitLab score)	See GitLab rows	Yes (added 2026-10-29)	2026-11-01
Cisco Secure Firewall ASA Software	Listed releases in 9.16, 9.18, 9.19, 9.20, 9.22, 9.23 and 9.24, only with SSL VPN reachable and secondary authentication on a tunnel group	9.16.4.104; 9.18.4.96; 9.20.4.50; 9.22.3.200; 9.23.1.48; 9.24.1.27 and 9.24.10.1. No 9.19 row is listed; use Cisco Software Checker.	CVE-2026-76418	8.6	0.008 (57th percentile, 2026-11-02)	Yes (added 2026-10-29)	2026-11-01
Cisco Secure Firewall Threat Defense (FTD) Software	Listed releases in 7.0, 7.2, 7.3, 7.4, 7.6, 7.7, 10.0 and 10.1, under the same conditions	7.0.11; 7.2.13; 7.4.9; 7.6.7; 7.7.14; 10.0.3; 10.1.1. No 7.3 row is listed; use Cisco Software Checker.	CVE-2026-76418	8.6	0.008 (57th percentile, 2026-11-02)	Yes (added 2026-10-29)	2026-11-01

Immediate (0–24 hours)

- Inventory every self-managed GitLab instance, including lab and shadow servers, and record GitLab version, install type and Ruby version. `IT OPS` [S9] [S11]
- Preserve Workhorse, api_json, graphql_json, application_json, exceptions_json, puma_stderr and Sidekiq logs, plus a VM snapshot where possible, before restarting or upgrading. Alpine lost some logs from its attack day. `SOC` [S11] [S21]

- Upgrade GitLab to the newest release for your branch, at minimum 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10 or 18.11.13. Plan for downtime on single-node instances because migrations must finish first. `IT OPS` [S8] [S9]
- On self-compiled installs and custom images, update Ruby to 3.3.13, 3.4.12, 4.0.9 or later and confirm the running version. If you use alpinelinux/gitlab, re-pull 19.3.6 or later, since images pulled before 2026-10-27 are vulnerable. `IT OPS` [S9] [S10] [S11]
- Hunt GitLab logs back to at least 2026-10-12 using the six GitLab detections, then check for git-owned files in /tmp, unexpected Puma or Sidekiq children, outbound connections, and changed crontabs or SSH keys. Federal agencies must meet CISA's forensic triage requirement; other organizations should treat it as best practice. `SOC` [S3] [S8] [S16] [S17] [S18] [S19] [S20] [S21] [S28]
- Check each ASA/FTD device for all three exposure conditions: vulnerable release, reachable SSL VPN login service, and secondary-authentication-server-group on any relevant tunnel group including DefaultWEBVPNGroup. On FTD, review the deployed policy and running configuration in FMC or FDM. `IT OPS` [S15]
- Upgrade exposed ASA/FTD devices to Cisco's first fixed release or later, confirming the build with Cisco Software Checker. If an outage window is not yet possible, apply a temporary mitigation from the compensating list after testing. `IT OPS` [S15]
- Review the past 30 days for unexplained ASA/FTD reloads and repeated SSL VPN connections before them. Save logs and upstream flow data, and open a Cisco TAC case for any unexplained reload. `SOC` [S29] [S30]

Short term (1–7 days)

- If there are signs of code execution, or logs are too incomplete to exclude it, treat the server as compromised: rebuild it, replace gitlab-secrets.json, and rotate passwords, 2FA, access tokens, runner tokens, CI/CD variables, integration credentials, webhook secrets, mirror passwords and OAuth application secrets. `IT OPS` [S11] [S12] [S21]
- After any suspected GitLab compromise, assess downstream use of exposed CI/CD secrets, and verify recent commits, builds and releases against records held outside GitLab, as Alpine did. `SOC` [S11]
- Disable open registration or require admin approval, restrict who can create projects and personal access tokens, and enforce MFA. `IT OPS` [S12] [S14] [S16]
- Deploy the GitLab detections to the SIEM, including puma_stderr.log collection and multiline handling, and retire them once fixed versions are verified. `SOC` [S16] [S17] [S18] [S19] [S20] [S21]
- Audit in-house Ruby applications for regexes compiled from user input through Regexp.new, Regexp.union, Regexp.compile or interpolation, and update Ruby. Regexp.timeout and pattern length limits do not reliably protect against these bugs. `IT OPS` [S3] [S10]
- Ask managed service, hosting and software vendors whether they run self-managed GitLab or ASA/FTD VPN gateways, and for confirmation of patching and, for GitLab, Ruby verification. `LEADERSHIP` [S3] [S11]

Long term

- Keep GitLab on a fast patch path. Alpine now aims to apply critical releases within a day and to check each release for component patches. `LEADERSHIP` [S11]

- Log outbound and database connections from GitLab hosts, and keep logs longer than 14 days. Alpine could not rule out compromise largely because of these gaps. `SOC` [S11]
- Add verification independent of GitLab, such as signed release tags and offline signing keys. Alpine's signing keys were never on the GitLab server, which limited its risk. `IT OPS` [S11]
- Prefer official GitLab packages or images unless you can track Ruby and other component patches yourself. `LEADERSHIP` [S9] [S11]
- Add VPN gateway availability to external monitoring, send firewall logs off the device, and review whether a single reload would take down critical remote access. `IT OPS` [S27] [S30]

Workarounds & compensating controls

- GitLab: restrict anonymous access to public projects, stop untrusted users from creating or writing to them, and block the CI lint route. These cover only Rapid7's demonstrated route and do not fix the compiler. `IT OPS` [S13] [S14]
- GitLab: restrict inbound access to the web interface, such as behind a VPN or allowlist, until upgraded. `IT OPS` [S25]
- Cisco, where DefaultWEBVPNGroup does not use secondary authentication: run no tunnel-group-list enable in WebVPN configuration mode. Users must then know their connection profile name. `IT OPS` [S15]
- Cisco, where DefaultWEBVPNGroup uses secondary authentication: run no secondary-authentication-server-group. This lowers VPN security, so get leadership risk acceptance, test first, and keep it temporary. `IT OPS` [S15]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: CISA adds actively exploited GitLab RCE and Cisco ASA/FTD flaws to KEV
Published 2026-10-30 · `B2` Usually reliable, probably true
Briefing source. Its wording on Cisco 'initial access' does not fit a DoS flaw.

[S2] CISA: CISA Adds Two Known Exploited Vulnerabilities to Catalog
Published 2026-10-29 · `A1` Completely reliable, confirmed by other sources
Primary source for the KEV listing.

[S3] CISA: Known Exploited Vulnerabilities catalog (JSON feed, version 2026.10.30)
Published 2026-10-30 · `A1` Completely reliable, confirmed by other sources
Dates, required action, forensic triage field, ransomware field 'Unknown'. Read via a summarizing tool.

[S4] CVE Program: CVE-2026-97229 record
Published 2026-10-13 · **A1** Completely reliable, confirmed by other sources
Updated 2026-10-30. Includes CISA SSVC: exploitation active, automatable yes, technical impact total.

[S5] CVE Program: CVE-2026-76418 record
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
Updated 2026-10-30. Includes CISA SSVC: exploitation active, automatable yes, technical impact partial.

[S6] NIST NVD: CVE-2026-97229 API record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Date is last modified. Lists GitLab and Ruby as affected.

[S7] NIST NVD: CVE-2026-76418 API record
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Date is last modified. Confirms score and KEV dates.

[S8] GitLab: GitLab patch release 19.4.2, 19.3.5, 19.2.8
Published 2026-10-12 · **A1** Completely reliable, confirmed by other sources
Vendor advisory; links six threat detections.

[S9] GitLab: GitLab patch release 19.5.1 (CVE-2026-110264)
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
Vendor advisory; states the Ruby upgrade requirement for own-Ruby installs.

[S10] Ruby: Regexp compilation fixes for GitLab CVEs
Published 2026-10-23 · **A1** Completely reliable, confirmed by other sources
Upstream maintainers; root-cause mapping and fixed Ruby versions.

[S11] Alpine Linux: GitLab security incident: attempted exploitation of CVE-2026-97229
Published 2026-10-28 · **A2** Completely reliable, probably true
First-hand victim account, updated 2026-10-30. Publishes no technical indicators.

[S12] Alpine Linux: GitLab is back: what you need to do
Published 2026-10-30 · **A2** Completely reliable, probably true
Lists secrets reset and user and maintainer actions.

[S13] Rapid7: Rapid7 Analysis: GitLab CI/CD Regex Integer Overflow (CVE-2026-97229)
Published 2026-10-16 · **A2** Completely reliable, probably true
Original research reproduced on 19.4.1-ce.0. The undisclosed in-the-wild route may differ.

[S14] Rapid7: CVE-2026-97229: Critical Unauthenticated Remote Code Execution in GitLab
Published 2026-10-13 · **A2** Completely reliable, probably true
Updated 2026-10-30. Questions the fully unauthenticated rating.

[S15] Cisco PSIRT: Secure Firewall ASA and FTD Remote Access SSL VPN Tunnel DoS Vulnerability (cisco-sa-asaftd-tunnel-dos-s6mgkb75)
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
Vendor advisory v1.0; authoritative for fixes and mitigation.

[S16] GitLab Security: Detection: GraphQL ciLint hostile regexp
Published · **A2** Completely reliable, probably true
Vendor rule, marked experimental; publication date not shown.

[S17] GitLab Security: Detection: CI lint Workhorse worker crash
Published · **A2** Completely reliable, probably true
Vendor rule; publication date not shown.

[S18] GitLab Security: Detection: CI regexp guard rejection
Published · **A2** Completely reliable, probably true
Vendor rule; publication date not shown.

[S19] GitLab Security: Detection: CI regexp oversized non-ASCII path
Published · **A2** Completely reliable, probably true
Vendor rule; publication date not shown.

[S20] GitLab Security: Detection: CI lint scripted client error burst
Published · **A2** Completely reliable, probably true
Vendor rule; publication date not shown.

[S21] GitLab Security: Detection: Onigmo native worker crash
Published · **A2** Completely reliable, probably true
Vendor rule; publication date not shown.

[S22] The Hacker News: Attacker Tried to Exploit Alpine Linux's GitLab via CVSS 10.0 Flaw Its Ruby Left Open
Published · **B2** Usually reliable, probably true
Adds context on the 19.3.4 advisory change and Rapid7's route. Exact publication date not captured; it describes status as of 2026-10-29.

[S23] The Hacker News: Cisco patches actively exploited ASA and FTD flaw
Published · **B2** Usually reliable, probably true
Confirms Cisco did not disclose when attacks began. Publication date not captured.

[S24] BleepingComputer: CISA says max severity GitLab flaw now exploited in the wild
Published 2026-10-30 · **B2** Usually reliable, probably true
Cites Shadowserver's count of nearly 2,800 exposed GitLab CE instances. Shadowserver data not independently checked.

[S25] Censys: CVE-2026-97229 exposure advisory
Published 2026-10-13 · **B2** Usually reliable, probably true
Exposure snapshot from the day after the patch, so now dated. Its 'no known exploitation' statement is superseded by the KEV listing.

[S26] Canadian Centre for Cyber Security: Cisco security advisory (AV26-1102)
Published 2026-10-29 · **A2** Completely reliable, probably true
Independent confirmation of exploitation statement. Lists 9.23.1.4 where Cisco lists 9.23.1.48; Cisco's value is used.

[S27] Center for Internet Security (MS-ISAC): A Vulnerability in Cisco Secure Firewall ASA and FTD Could Allow for Denial of Service (2026-124)
Published 2026-10-29 · **A2** Completely reliable, probably true
Risk ratings for government and business.

[S28] CISA: BOD 26-04: Prioritizing Security Updates Based on Risk
Published 2026-06-10 · **A1** Completely reliable, confirmed by other sources
Applies to federal civilian agencies. Forensic triage steps are in separate guidance not reviewed here.

[S29] Rescana: Cisco Secure Firewall ASA and FTD CVE-2026-76418: Exploited SSL VPN DoS Flaw Added to CISA KEV
Published · **C2** Fairly reliable, probably true
States no IOCs were published as of 2026-10-30. Reload review guidance is its own, not Cisco's.

[S30] SOC Prime: CVE-2026-76418: Cisco Secure Firewall Zero-Day Exploited in SSL VPN Attacks
Published · **C3** Fairly reliable, possibly true
Vendor blog, used for behavioral detection ideas and its statement that no reproducible public PoC was seen.

[S31] FIRST: EPSS API: CVE-2026-97229, CVE-2026-76418, CVE-2026-110264
Published 2026-11-02 · **A2** Completely reliable, probably true
Model-based probability, not evidence of exploitation.

[S32] SecurityOnline: GitLab RCE CVE-2026-97229 PoC disclosed
Published 2026-10-14 · **C3** Fairly reliable, possibly true
Used only for the country breakdown it attributes to Censys. Its status field contradicts its own body on exploitation, and the country figures were not seen on the Censys page.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-10-12	GitLab releases 19.4.2, 19.3.5 and 19.2.8 fixing CVE-2026-97229.	[S8]
2026-10-13	CVE published; Rapid7 publishes a proof of concept; Censys counts 25,766 hosts on vulnerable versions. Alpine mistakenly upgrades to 19.3.4.	[S4] [S11] [S14] [S25]
2026-10-16	Rapid7 publishes its technical analysis.	[S13]
2026-10-20	A newly registered account begins probing Alpine's GitLab server.	[S11]
2026-10-21	Main attack on Alpine: eight worker crashes, four partial exploit runs, 502 errors and failed CI jobs; the attacker downloads the GitLab image. GitLab separately releases fixes for CVE-2026-110264.	[S9] [S11]
2026-10-22	Alpine upgrades to 19.3.6, which does not fix its server because the image uses unpatched Ruby.	[S11]
2026-10-23	Alpine blocks the attacker's account. Ruby announces 3.3.13, 3.4.12 and 4.0.9.	[S10] [S11]
2026-10-25	The attacker returns over 25-26 October to try to regain access; attempts fail. Alpine finds the server still vulnerable on 26 October.	[S11]
2026-10-27	Alpine restricts GitLab to developers and build servers and begins a rebuild; fixed image published.	[S11]
2026-10-28	Alpine publishes its incident report. Cisco publishes its advisory and states it became aware of exploitation in October.	[S11] [S15]
2026-10-29	CISA adds both CVEs to KEV. The Canadian Cyber Centre and CIS/MS-ISAC issue advisories on the Cisco flaw.	[S2] [S26] [S27]
2026-10-30	Alpine announces GitLab is back on a rebuilt server running 19.3.7 and Ruby 3.3.13. The Hacker News and BleepingComputer report on the KEV additions.	[S1] [S12] [S24]
2026-11-01	Federal due date for both CVEs.	[S3]

Relevance to Indianapolis, Indiana & managed clients

Nothing in the sources names an Indianapolis or Indiana victim, and no exposure figure reviewed here breaks down by state. Secondary coverage attributes a count of 2,927 exposed US hosts on vulnerable versions to Censys as of mid-October [S32], so treat this as a dated national indicator only. Indiana organizations are not bound by the federal deadline, since BOD 26-04 covers federal civilian agencies [S28], but that date is a useful benchmark. For local government, school districts and hospitals, the Cisco flaw is likely the more common exposure. Any ASA/FTD gateway using secondary authentication could lose VPN service during an attack, which would interrupt remote clinicians, staff and vendors, and a reload may also briefly disrupt other traffic through a device without failover (our inference). CIS rates the risk High for large and medium governments and businesses and Medium for small ones [S27]. Manufacturers, software firms, universities and research groups running self-managed GitLab face the more severe risk: CI/CD secrets and runner tokens can lead to cloud accounts, production systems and customer software. Small and mid-size firms may have a GitLab server set up by a former developer or contractor with open registration and no log forwarding, so finding it is the first task. For managed IT clients: run the ASA/FTD configuration check and GitLab inventory across all tenants, report who is exposed, schedule firewall upgrades in coordinated windows, and tell clients clearly that the secondary authentication mitigation reduces security. Do not close a GitLab ticket on the version number alone; record Ruby verification and hunt results too.

Intelligence gaps

- Actor identity and motive for both campaigns are unknown.
- Scale is unknown: neither CISA nor the vendors have published victim counts, and no confirmed GitLab compromise has been named in the sources reviewed.
- CISA has not published its evidence of exploitation for either CVE. It is unclear whether the GitLab listing rests on Alpine alone or on wider activity.
- How an attacker can exploit CVE-2026-97229 without write access to a public project remains unexplained. GitLab has not published the conditions behind its PR:N rating, and Alpine has not said how its attacker's configurations reached GitLab.
- When exploitation of CVE-2026-76418 began, what the crafted request looks like, and why attackers want the reload are all undisclosed.
- No fixed-release row appears in Cisco's advisory for ASA 9.19 or FTD 7.3, although the CVE record lists those releases as affected. Confirm the upgrade path with Cisco Software Checker.
- Exposure data is uneven and dated: Censys's figures date from 2026-10-13 and differ greatly from Shadowserver's nearly 2,800 exposed GitLab CE instances. No exposure count was found for ASA/FTD devices with the vulnerable configuration.
- CISA lists ransomware use as Unknown for both CVEs. Watch for a change in that field, new vendor indicators, a Cisco advisory revision, and any public reproducible exploit for the Cisco flaw.
- CISA's forensic triage guidance was not reviewed in detail for this report. The GitLab work item returned no readable issue content, and the HackerOne reports and Metasploit pull request were not opened.

Other notes

- Corrections to the briefing excerpt: Cisco says it became aware of exploitation in October, not that exploitation began then [S15] [S23]. The Alpine attempt is not established as failed; Alpine found no evidence

of success but could not rule it out [S11]. Fixed versions are available and are listed in this report.

- Dispute over 'unauthenticated': GitLab's vector uses PR:N, but Rapid7 says only the final lint request on its route is unauthenticated and that staging the content needs write access to a public project [S4] [S13] [S14]. Do not assume closed registration makes a server safe, since the real-world route may differ and internal users or stolen accounts could meet the requirement.
- Source discrepancy on request method: Rapid7 describes GET to the REST CI lint route, while GitLab's rules match POST [S13] [S17] [S20]. This report's Workhorse query covers both.
- Version confusion: GitLab's advisory originally named 19.3.4 as fixed and later listed it as affected, according to The Hacker News [S22]. GitLab's rules note that 19.4.1 is insufficient because this flaw bypasses its guards [S17] [S18].
- Root cause: Ruby says CVE-2026-97229 shares a root bug with CVE-2026-93577, and GitLab also assigned CVE-2026-89078 and CVE-2026-110264 to related regex issues. Ruby has not requested its own CVE IDs, so scanners may not flag system Ruby under a Ruby-specific CVE [S10]. CISA warns other products may be affected by the same underlying issue [S3].
- NVD lists Ruby 4.0 as fixed in 4.0.8 for CVE-2026-97229 [S6], which matches Ruby's fix table, but Ruby states 4.0.9 contains all the related fixes [S10]. Use 4.0.9 or later.
- CVE-2026-110264 did not appear in the portion of the KEV feed reviewed, which was newest first and reached back to 2026-09-16 in catalog version 2026.10.30 [S3]. Recheck, because this could change quickly.
- Canadian Cyber Centre's fixed version for ASA 9.23 reads 9.23.1.4, while Cisco's advisory reads 9.23.1.48 [S15] [S26]. Cisco's value governs. Some low-quality sites claim GitLab 17.8.1 as a fix; no primary source supports that and it was not used.
- Coverage of a separate Cisco SD-WAN campaign (UAT-11473, CVE-2026-20127) appears on the same Hacker News page [S23]. Nothing in the sources links it to CVE-2026-76418.
- EPSS scores on 2026-11-02 were 0.273 for CVE-2026-97229, 0.008 for CVE-2026-76418 and 0.013 for CVE-2026-110264 [S31]. The low Cisco score should not lower its priority because confirmed exploitation outweighs a model estimate.
- Source content was retrieved through a summarizing fetch tool, so check exact rule syntax against the original GitLab detection files before deployment.

CTI-20261103-02 v1.0 · Generated 2026-11-03 08:48 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.